EXPERIMENT: SOFTWARE COMPOSITION ANALYSIS (SCA) AND SBOM USING FOSSA

AIM

To perform Software Composition Analysis (SCA) using FOSSA to identify open-source dependencies, security vulnerabilities, and license compliance issues, and to generate SPDX and CycloneDX SBOMs.

PROCEDURE

1. Open PowerShell as Administrator and install the FOSSA CLI.
2. Verify that FOSSA CLI has been installed successfully.
3. Create a FOSSA account and generate a Full Access API token from the account settings.
4. Configure the API token in PowerShell.
5. Create a sample project and add an open-source dependency with a known vulnerability.
6. Navigate to the project directory and perform dependency analysis using FOSSA.
7. Run the FOSSA test to identify security vulnerabilities and license-related issues.
8. Open the FOSSA web dashboard and select the analyzed project. Review the Vulnerabilities section for CVE details, severity, affected packages, and remediation recommendations.
9. Review the Licenses section to identify license types and possible compliance issues.
10. Generate an SPDX SBOM using the FOSSA CLI and save it in text and JSON formats.
11. Open the FOSSA dashboard and navigate to Reports → SBOM. Select CycloneDX and download the SBOM in JSON or XML format.
12. Examine both SBOM files and compare their package names, versions, licenses, and dependency relationships.

COMMANDS

```
Set-ExecutionPolicy Bypass -Scope Process -Force; iex ((New-Object
System.Net.WebClient).DownloadString('https://raw.githubusercontent.com/fossas/fossa-cli/
master/install-latest.ps1'))

fossa --version

$env:FOSSA_API_KEY="YOUR_FULL_ACCESS_API_KEY"

mkdir fossa-lab
cd fossa-lab

npm init -y

npm install lodash@4.17.20

fossa analyze

fossa test

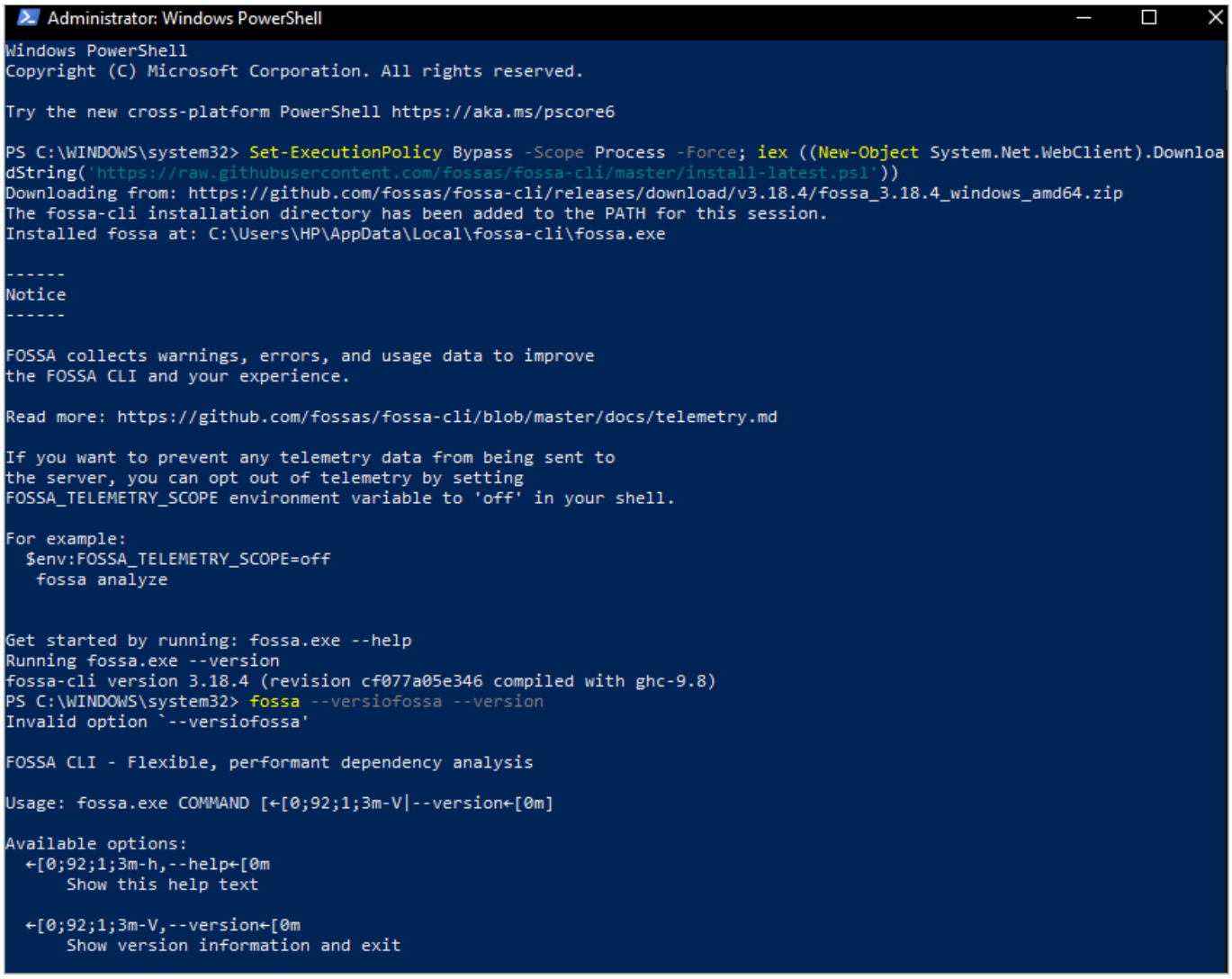
fossa report attribution --format spdx

fossa report attribution --format spdx > sbom-spdx.txt

fossa report attribution --format spdx-json > sbom-spdx.json
```

OUTPUT

1. FOSSA CLI Installation and Version Check



NAME: LAKSHMI PRIYA **ROLL NO: 231901025**

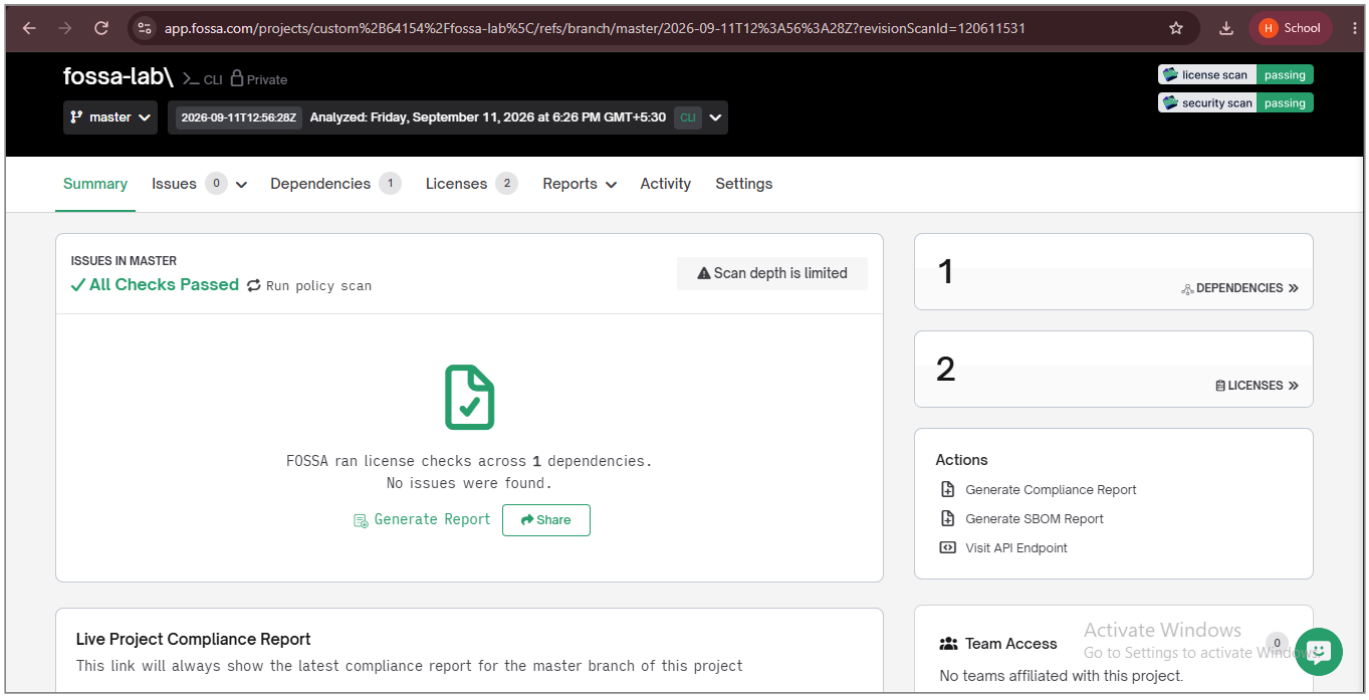
2. Dependency Analysis (fossa analyze)

```
PS C:\WINDOWS\system32\fossa-lab> fossa analyze
Unable to infer project revision from VCS, using current timestamp as the revision.
[ 0 Waiting / 1 Running / 0 Completed ]
[ 13 Waiting / 4 Running / 0 Completed ]
[ 14 Waiting / 4 Running / 0 Completed ]
[ 15 Waiting / 4 Running / 0 Completed ]
[ 17 Waiting / 4 Running / 0 Completed ]
[ 19 Waiting / 4 Running / 0 Completed ]
[ 21 Waiting / 4 Running / 0 Completed ]
[ 22 Waiting / 4 Running / 0 Completed ]
[ 24 Waiting / 4 Running / 0 Completed ]
[ 25 Waiting / 4 Running / 0 Completed ]
[ 27 Waiting / 4 Running / 0 Completed ]
[ 28 Waiting / 4 Running / 0 Completed ]
[ 29 Waiting / 4 Running / 0 Completed ]
[ 31 Waiting / 4 Running / 0 Completed ]
[ 32 Waiting / 4 Running / 0 Completed ]
[ 33 Waiting / 4 Running / 0 Completed ]
[ 32 Waiting / 4 Running / 1 Completed ]
[ 28 Waiting / 4 Running / 5 Completed ]
[ 25 Waiting / 4 Running / 8 Completed ]
[ 24 Waiting / 4 Running / 9 Completed ]
[ 21 Waiting / 4 Running / 12 Completed ]
[ 20 Waiting / 4 Running / 13 Completed ]
[ 17 Waiting / 4 Running / 16 Completed ]
Analyzing npm project at C:\Windows\System32\fossa-lab\
[ 12 Waiting / 4 Running / 22 Completed ]
[ 10 Waiting / 4 Running / 24 Completed ]
[ 9 Waiting / 4 Running / 25 Completed ]
[ 8 Waiting / 4 Running / 26 Completed ]
[ 5 Waiting / 4 Running / 29 Completed ]
[ 4 Waiting / 4 Running / 30 Completed ]
[ 2 Waiting / 4 Running / 32 Completed ]
[ 0 Waiting / 4 Running / 34 Completed ]
[ 0 Waiting / 3 Running / 35 Completed ]
[ 0 Waiting / 2 Running / 36 Completed ]
[ 0 Waiting / 1 Running / 37 Completed ]

Scan Summary
------------
fossa-cli version 3.18.4 (revision cf077a05e346 compiled with ghc-9.8)
fossa endpoint server version: 4.34.102

1 projects scanned;  0 skipped,  1 succeeded,  0 failed,  0 analysis warnings
```

3. Web Dashboard Compliance & Security Overview



4. SPDX Report Generation

```
#### Files

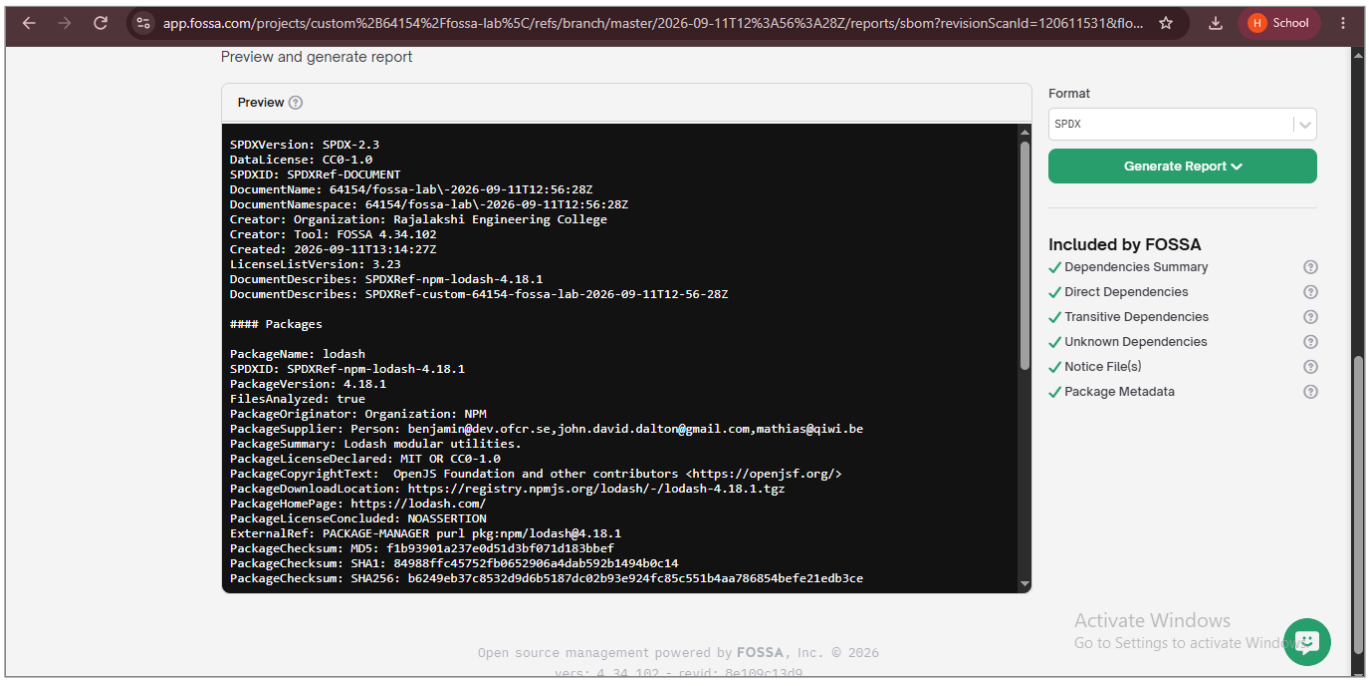
FileName: package.json
SPDXID: SPDXRef-npm-lodash-4.18.1-package.json
Comment: extracted from SPDXRef-npm-lodash-4.18.1
LicenseConcluded: MIT
LicenseInfoInFile: MIT
FileChecksum: MD5: 7abc1a233092fc104c7af72a89c0829c
FileChecksum: SHA1: 89690ac571dcf4c9c40c842efed3f11171d07b29
FileChecksum: SHA256: e5dcffe836b6ec8a58e492419b550e65fb8cbdc308503979e5dacb33ac7ea3b7


FileName: LICENSE
SPDXID: SPDXRef-npm-lodash-4.18.1-LICENSE
Comment: extracted from SPDXRef-npm-lodash-4.18.1
LicenseConcluded: (MIT OR CC0-1.0)
LicenseInfoInFile: MIT
LicenseInfoInFile: CC0-1.0
FileChecksum: MD5: c31ca6abdd4c21b908e9436a0ba3fcf9
FileChecksum: SHA1: 3a9fcb28154139567af2cb391af4736ea3f2eeed
FileChecksum: SHA256: b5037b932d38aafc61ff212ad30e94d87a173a8edf356a18836a42290c896727


PS C:\WINDOWS\system32\fossa-lab> fossa report attribution --format spdx > sbom-spdx.txt
Unable to infer project revision from VCS, using current timestamp as the revision.

Using project name: `fossa-lab\`
Using revision: `2026-09-11T12:56:28Z`
[WARN] "spdx" format may change independent of CLI version: it is sourced from the FOSSA service.
[ Waiting for build completion... ]
[ Waiting for scan completion... ]
[ Fetching attribution report... ]
PS C:\WINDOWS\system32\fossa-lab>
```

5. Dashboard SBOM Report Preview



RESULT

The sample project was successfully analyzed using FOSSA SCA. The open-source dependencies, security vulnerabilities, CVE details, and license information were identified. SPDX and CycloneDX SBOMs were successfully generated and examined, providing information about the project's software components, versions, licenses, and dependency relationships.